

Cloud Account Compromise response

Cloud · **High** severity · SOC IR Playbook

Incident type	Identity Compromise - Cloud Account
Severity	High
Priority	Critical if lateral movement or data access is observed
Detection sources	SIEM, CASB, Cloud-native logging (e.g., AWS CloudTrail, Azure AD), Email gateway, EDR

Scenario

An attacker gains unauthorized access to a user's cloud account, possibly through phishing, password spraying, token theft or OAuth abuse. The attacker may access email, storage, admin functions or cloud infrastructure.

MITRE ATT&CK

T1078, T1087.004, T1531, T1556.004

Preparation

Enable cloud logging Use AWS CloudTrail, Azure Sign-in logs, Google Workspace audit logs Implement MFA Enforce for all users, especially privileged accounts Monitor user behaviour Integrate cloud logs into SIEM, use anomaly detection Set geo-restrictions and login alerts Alert on impossible travel or first-time access from unknown IPs Apply least privilege Use RBAC policies and regular permission audits

Detection & Analysis

Detect login anomalies Failed logins, impossible travel, MFA bypass alerts Correlate with threat intel Match IPs, user agents or domains with IOC feeds Check access logs Review mailbox, storage, IAM or API activity after compromise Look for privilege escalation Identify if the attacker attempted to gain more access or created backdoor accounts

Containment

Revoke sessions and tokens Invalidate all active sessions, OAuth tokens and refresh tokens Reset password Enforce strong password and enable MFA if not already enabled Suspend account If compromise is confirmed and impact is high Block IP addresses If attacker used known bad IPs or TOR exit nodes

Eradication

Remove malicious inbox rules or automation Clean auto-forward rules, inbox filters and calendar sharing changes Disable rogue applications Revoke consent for unauthorised third-party apps Review admin roles Revert unauthorized admin access or privilege changes Restore modified data If integrity issues occurred (e.g., mailbox deletion, S3 file replacement)

Recovery

Re-enable account access After ensuring full control is restored and no persistence remains Notify affected users or stakeholders Especially if business email compromise (BEC) occurred Monitor for post-recovery login anomalies Use SIEM or CASB to detect reuse attempts or related attacks Update access policies Refine conditional access, session timeout and MFA enforcement rules

Lessons Learned & Reporting

Conduct root cause analysis Phishing, weak password, token theft, misconfiguration Update playbooks and detection rules Add improved indicators and logic to SIEM or CASB rules Educate users Reinforce training on phishing and cloud security practices Document incident report Include timeline, method of access, affected resources and actions taken Fulfill legal reporting obligations If applicable (e.g., PDPA, GDPR, customer SLAs)

Tools typically involved

SIEM (e.g., Microsoft Sentinel, Splunk, QRadar); Cloud-native logs (e.g., AWS CloudTrail, Azure Log Analytics, Google Workspace audit logs); CASB (e.g., Netskope, Microsoft Defender for Cloud Apps); Cloud Security Posture Management (e.g., Wiz, Prisma Cloud); EDR/XDR with identity correlation (e.g., CrowdStrike, Cortex XDR)

Success metrics (SLA targets)

Detection Time <15 minutes from suspicious login Response Time <1 hour to lock and reset credentials
Containment Time <30 minutes after confirmation Post-incident Monitoring Period 7-14 days minimum